



PowerShell Conference Europe

Next Up:

Evgenij Smirnov

3

2

1



PowerShell Conference Europe

Who am I?

Applied tokenology for PowerShellers

Evgenij Smirnov

Many thanks to our sponsors:

Devolutions



Jane Street



Microsoft



SynEdgy



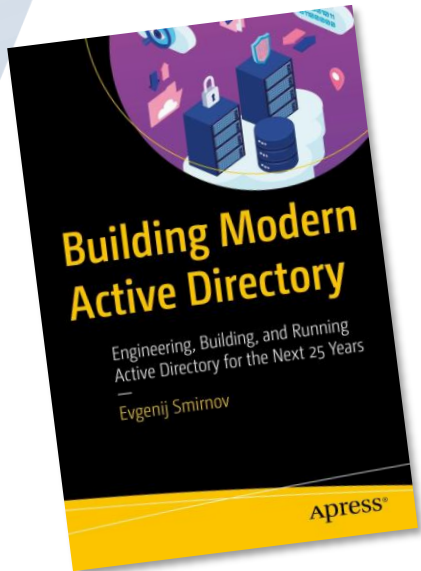
@ it-pro-berlin.de



SPEAKER

Evgenij Smirnov

- I live in Berlin
- Principal Solutions Architect @ Semperis
- 30+ years of consulting and delivery
- PowerShell MVP since 2020
- Attended all PSConfEU since 2016
 - ...and spoke at seven of them, including this one
- AMA about Active Directory
 - ...chances are, you'll not like the answer



@it-pro-berlin.de

In this session

Imagine you are a well-behaved PowerShell script that hates hitting „Access Denied“ exceptions...

- Who am I?
- What can I do?
- Who is it that called me?
- Who will I be when I get there?

Not in this session

- Cloud (*well, maybe a little...*)
- Cryptocurrency
- Probabilistic text-extrusion machinery™
- Hardening
- Pentesting

Who am I?

...and if so, how many?



@ it-pro-berlin.de

AuthWhat?

Authentication,
while extremely important,
is mostly actually
just the precursor to
authorization



Demos

We love frantic
screen-hopping!



Who am I?

...and if so, how many?



@ it-pro-berlin.de

In Windows

`[Security.Principal.WindowsIdentity]::GetCurrent()`

- ...but what exactly does it tell us?
- ...are SIDs all there is?
WHOAMI /GROUPS can do that, after all...
- ...and what the heck are „claims“?

Am I running interactive?

- On any .NET / PS in Windows:
`[System.Environment]::UserInteractive`

Am I running elevated?

- On any .NET / PS in Windows:

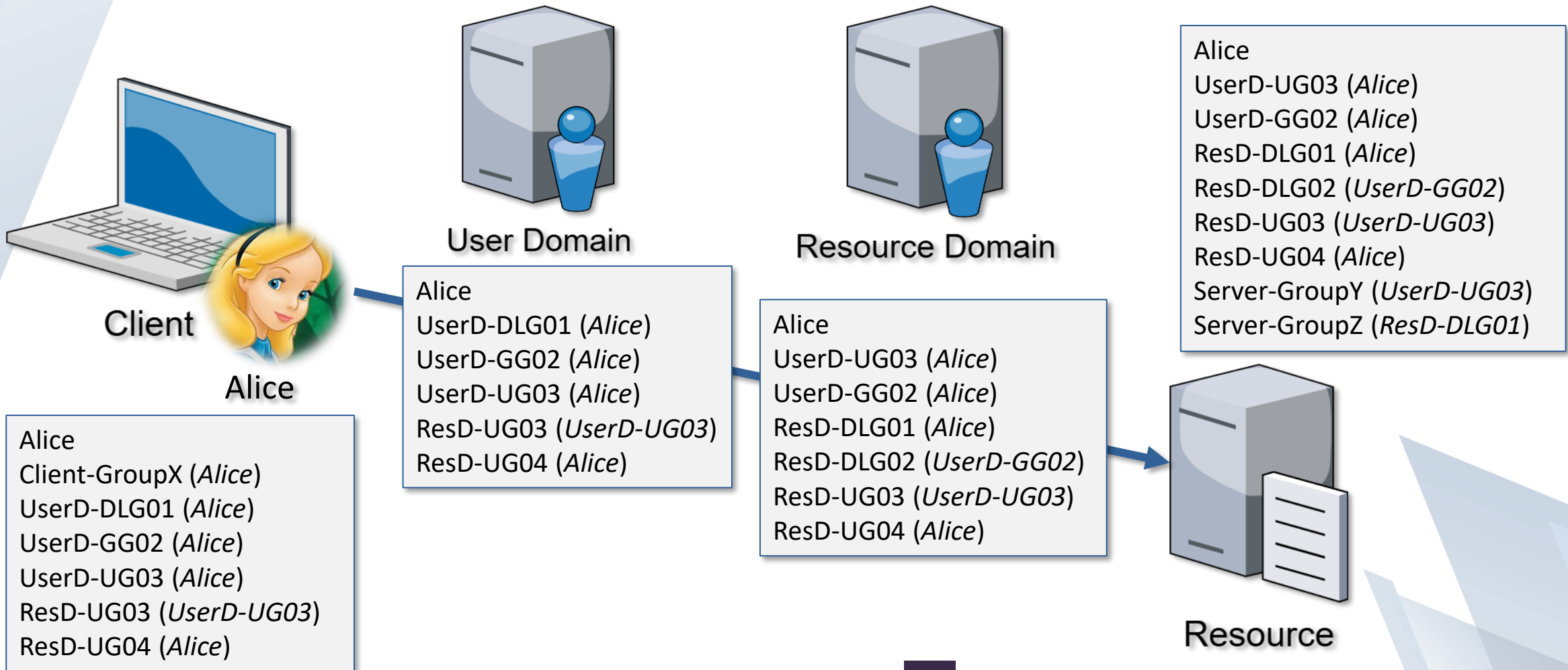
```
$wid = [Security.Principal.WindowsIdentity]::GetCurrent()
```

```
$prc = New-Object Security.Principal.WindowsPrincipal($wid)  
$prc.IsInRole([Security.Principal.WindowsBuiltInRole]::Administrator)  
$wid.Groups.Value.Contains('S-1-5-32-544')
```

- On .NET / PS7 in Windows/Linux:

```
[System.Environment]::IsPrivilegedProcess
```


Where is the token assembled?



Token Simulation

- Own domain: tokenGroups* (or local token minus local groups)
 - Requires a base search, lists SIDs
 - There are attributes for DNs but those are flawed 😞
- Foreign domain: not quite so easy 😞
 - The good thing is, only DL groups will be missing...
 - ...but there is *no IN_CHAIN* for cross-domain chains
- It becomes so much easier when looking for a *particular* DL group in a foreign domain!

Privileges

What can I actually *do* with all these claims?



What can my process do?

- AuthZ = mapping of claims to capabilities
- Capabilities:
 - Access rights to certain objects (permissions)
 - Rights to perform actions within the system (privileges)
- Windows has 35 distinct privileges
<https://learn.microsoft.com/en-us/windows/win32/secauthz/privilege-constants>
- No .NET methods exist to determine which ones are active



Remoting

Who am I if I connect to a different system?



@ it-pro-berlin.de

WinRM remoting /JEA

- A JEA endpoint
 - often runs as a highly-privileged account...
 - ...but restricts what the user can do with those privileges
- Can we determine...
 - what the virtual account can do (avoid ACCESS_DENIED)?
 - who the calling user is (make remote decisions)?
- Turns out, we can (under certain conditions)!

Working under JEA endpoint

- In Full Language Mode, all previously shown capabilities can be used as-is
 - In other language modes, they would have to be implemented within the modules loaded by the JEA session configuration!
- In Full and Constrained Language Mode,
\$PSSenderInfo
carries information about the caller, including full local identity as shown before!

SSH remoting

- SSH Remoting with password auth to Server < 2025:
 - Default config allows anyone to connect (but you have to enable password auth)
 - They have a full local session in their security context
 - Logon restriction policies do not apply (Logon Type 8)
 - **Credentials can be at risk!** (*again*, Logon Type 8 😊)
- SSH Remoting with pwd auth to Server 2025:
 - Group restrictions are enabled by default



What about SSH with a key pair?

- Same considerations apply, but...
 - Credentials are not at risk (Logon Type 3)
 - No second hop, just like WinRM

When is a door not a door?

When someone goes and does `runas /netonly` ...



@ it-pro-berlin.de

Am I running under /netonly?

- Bare minimum:
 - Is this session running under `runas /netonly` ?
- Would be great to know:
 - Username and -domain of the secondary account
- Ideally:
 - Username, domain and password
 - It **must** be stored somewhere, right?

Am I running under /netonly?

Command Prompt

```
c:\>c:\temp\GetOwnLogonId.exe
Own Auth ID: 0xF7ACD2

c:\>runas /netonly /user:SOMEDOMAIN\SOMEUSER cmd
Enter the password for SOMEDOMAIN\SOMEUSER:
Attempting to start cmd as user "SOMEDOMAIN\SOMEUSER"

c:\>
```

cmd (running as SOMEDOMAIN\SOMEUSER)

```
Microsoft Windows [Version 10.0.20348.5139]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>c:\temp\GetOwnLogonId.exe
Own Auth ID: 0x10AEA86

C:\Windows\system32>
```

Security Number of events: 29,703

Keywords	Event ID	Date and Time	Task Category	Source
Audit Success	4624	18.05.2026 21:27:42	Login	Microsoft Windows security auditing.

Event 4624, Microsoft Windows security auditing.

General Details

An account was successfully logged on.

Subject:

- Security ID: DEV\root
- Account Name: root
- Account Domain: DEV
- Logon ID: 0xF7ACD2

Logon Information:

- Logon Type: 9
- Restricted Admin Mode: -
- Virtual Account: No
- Elevated Token: No

Impersonation Level: Impersonation

New Logon:

- Security ID: DEV\root
- Account Name: root
- Account Domain: DEV
- Logon ID: 0x10AEA86
- Linked Logon ID: 0x0
- Network Account Name: SOMEUSER
- Network Account Domain: SOMEDOMAIN
- Logon GUID: {00000000-0000-0000-0000-000000000000}



Am I running under /netonly?

- Determine if session is running in /netonly:
 - Should be possible with the processes own rights
- Determine the outbound user from EventLogs:
 - Permission to read Security event log
- Recover outbound user (including password):
 - Admin permissions, requires elevation
 - Will not work under RunAsPPL or CredGuard
 - May or may not help validate the credential

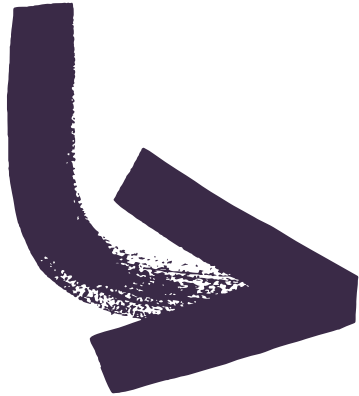
Q&A

15 minutes



@ it-pro-berlin.de

GIVE ME FEEDBACK



Who Am I? Applied Tokenology for PowerShellers



@ it-pro-berlin.de